IMPLEMENTACIÓN POLÍTICAS DE SEGURIDAD DLP

Manuel Rosario Marín Fernández

Fecha: 03/03/2026

1. Índice

1. Introducción al Data Loss Prevention..... 3
2. Clasificación de Datos..... 3
3. Acceso y Control: Principio del Menor Privilegio..... 3
4. Monitoreo y Auditoría.....4
5. Prevención de Filtraciones..... 4
6. Educación y Concienciación.....4

1. Introducción al Data Loss Prevention

El Data Loss Prevention (DLP) es un conjunto de estrategias y herramientas diseñadas para garantizar que los usuarios no envíen información sensible o crítica fuera de la red corporativa de manera no autorizada. Su importancia radica en la mitigación del riesgo operacional y legal, pero sobre todo garantiza la **confidencialidad, integridad y disponibilidad** de los activos, protegiendo a la empresa de sanciones legales (como las del GDPR), daños reputacionales y pérdidas financieras directas.

2. Clasificación de Datos

Nuestra organización clasifica sus activos de información en función de su *valor*, *sensibilidad* y el *impacto potencial* que supondría su pérdida. Se establecen tres categorías obligatorias:

- **Datos Públicos**: Información destinada a la difusión externa cuyo compromiso no supone un riesgo para la entidad. Por ejemplo, notas de prensa, catálogos.
- **Datos Internos**: Información operativa para uso exclusivo de empleados y socios autorizados; su divulgación podría causar inconvenientes a la empresa. Por ejemplo, procesos internos, memorándums.
- **Datos Sensibles**: Información crítica sujeta a regulaciones estrictas como la GDPR o secretos comerciales cuya filtración comprometería la viabilidad de la empresa. Por ejemplo, datos financieros, contratos, registros de salud o PII.

3. Acceso y Control

Para reducir la superficie de ataque, el acceso a la información se deberá regir estrictamente por la necesidad operativa del puesto de trabajo, aplicando el *principio de menor privilegio.*

- **Asignación de Permisos**: Los empleados sólo tendrán acceso a los recursos indispensables para sus tareas diarias, dando prioridad a los perfiles de "Solo Lectura" frente a los de edición para el personal no administrativo.
- **Flujo de Revisión**: El **Departamento de Seguridad de la Información, en concreto el CISO,** y los **Responsables de cada Área** realizarán auditorías trimestrales de permisos.
- **Procedimiento**: Se utilizará el sistema de gestión de IDs para revocar automáticamente accesos de personal inactivo o que haya cambiado de rol, asegurando que los privilegios no se acumulen con el tiempo.

4. Monitoreo y Auditoría

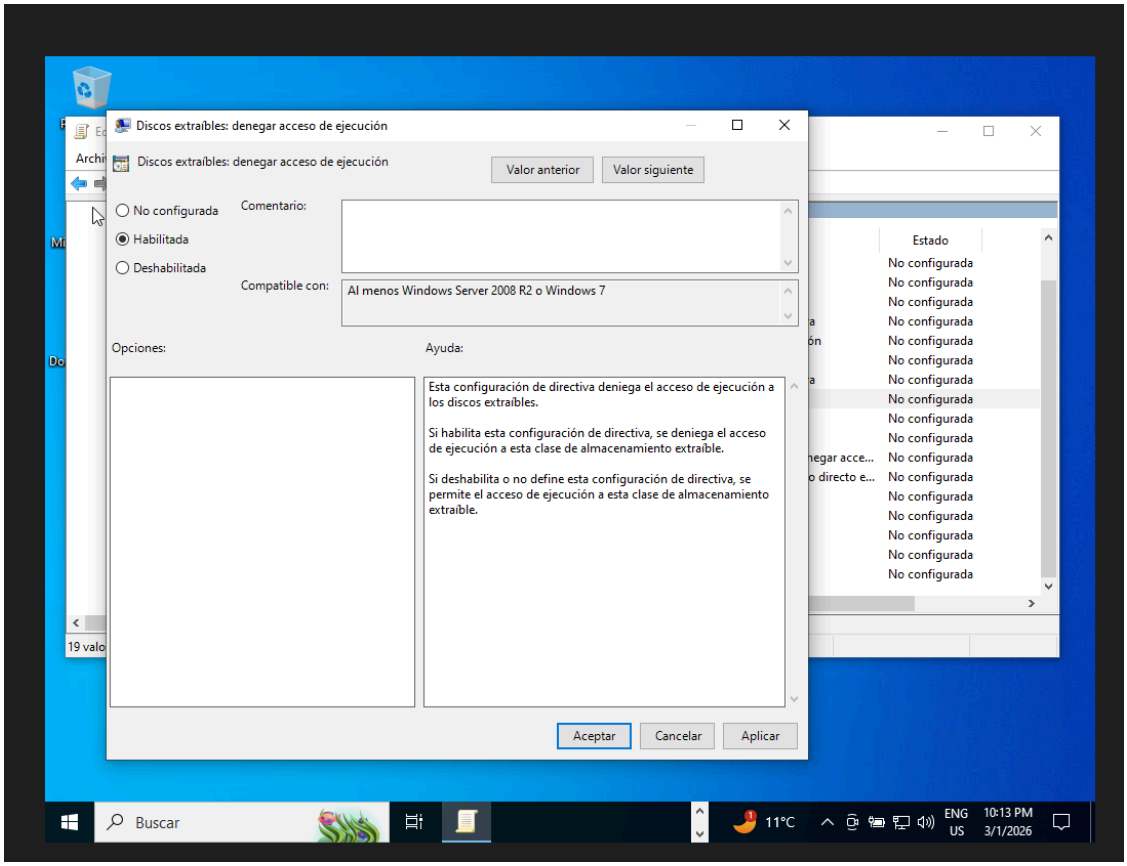
Se establecen reglas de vigilancia continua para detectar actividades sospechosas o intentos de acceso no autorizados.

- **Herramienta Central (SIEM)**: Se utilizará **Wazuh** para centralizar la telemetría de seguridad de los endpoints y sistemas en la nube.
- **Reglas de Monitoreo**: Wazuh rastreará eventos, alertando en tiempo real sobre la manipulación o descarga masiva de archivos etiquetados como "Sensibles".
- **Auditoría**: Se registrarán todos los accesos (quién, cuándo, qué y desde dónde) mediante el análisis de logs de Windows y entornos en la Nube, permitiendo realizar investigaciones forenses ante incidentes.

5. Prevención de Filtraciones

La defensa se aplica mediante capas tecnológicas que protegen el dato en sus tres estados (reposo, movimiento y uso):

- **Cifrado**: Los datos sensibles en reposo se protegerán mediante cifrado de disco y los datos en movimiento mediante protocolos SSL/TLS o VPNs seguras.
- **Controles de Endpoint**: Se bloqueará el uso de dispositivos USB no autorizados y se restringirá la función de copiar/pegar para aplicaciones que manejen PII.



- **Control de Compartición**: Se deshabilitará por defecto la compartición externa en servicios de almacenamiento (como Google Drive o OneDrive) para documentos clasificados como "Sensibles".

6. Educación y Concienciación

El contar con una plantilla educada y concienciada es uno de los pilares de la prevención de pérdida de datos. Atajando muchas de las malas prácticas o prácticas no seguras y conociendo cómo lidiar con sus consecuencias disminuye el riesgo de que, en caso de que se de una ataque o una brecha de seguridad se pierdan muchos datos. El personal recibirá formación semestral sobre:

- **Capacitación Regular**: Talleres trimestrales obligatorios sobre identificación de phishing, gestión de contraseñas y manejo ético de la privacidad.
- **Simulacros y Evaluación**: Realización de pruebas de ingeniería social y quizzes para medir la retención de conocimientos.
- **Cultura de Seguridad**: Promover la responsabilidad individual, informando a los empleados de que el cumplimiento normativo protege tanto a la organización como a nuestros propios derechos digitales.